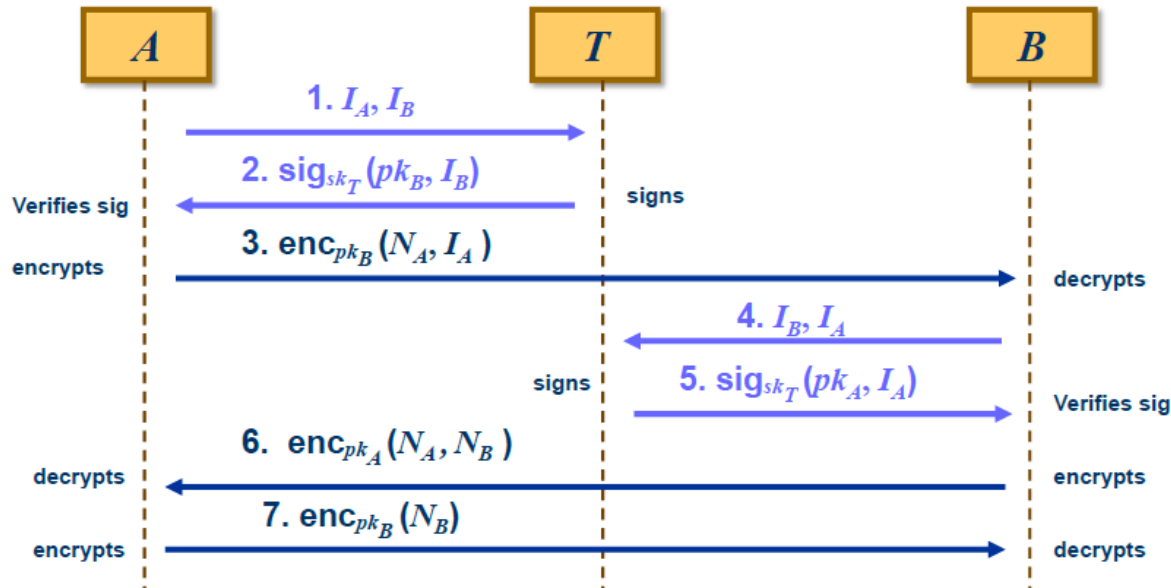


SECURING CRYPTOGRAPHIC PROTOCOLS-2



Needham-Schroeder PK: The Protocol



The protocol is interleaving of two logically disjoint protocols:

- Messages 1, 2, 4, and 5 are concerned with obtaining the peer's party public key from the authentication server
- Messages 3, 6 and 7 are concerned with authentication of *A* and *B*

Analysis of NS-PK Protocol (1)

- **Messages 1 and 2: Allow A to find B 's public key**
 - Message 2 is signed to provide integrity of pk_B
 - A knows that the name of the intended recipient B was correctly communicated to T because that name was returned in the message 2
- **Message 3: A initiates communication with B**
 - Can be only understood by A
 - Contains nonce N_A generated by A
 - If N_A is returned to A , it guarantees freshness
- **Messages 4 and 5: Allow B to find A 's public key**
 - Similar to messages 1 and 2

Analysis of NS-PK Protocol (2)

4

- **Messages 6 and 7**
 - Double handshake to authenticate A and B to one another and to establish the time integrity for the conversation
 - When A receives mess. 6, it should be assured that it is talking to B , since only B should be able to decrypt mess. 3 to obtain N_A
 - When B receives mess. 7, it should be assured that it is talking to A , since only A should be able to decrypt message 6 to obtain N_B

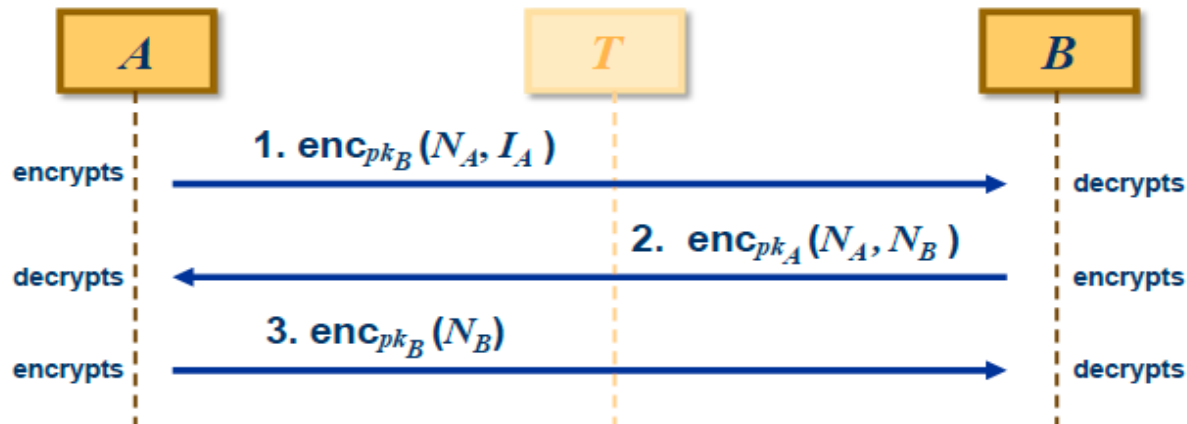
➔ **Goal achieved:**

Mutual entity authentication of A and B

Simplified NS-PK Protocol

5

If we assume that each party initially knows the public key of the peer party, the protocol reduces to three messages:



The exchanged nonces N_A and N_B can be used as shared secrets for establishment of a session key

$$K_{AB} = f(N_A) \text{ or } K_{AB} = f(N_B) \text{ (key transport)}$$

$$K_{AB} = f(N_A, N_B) \text{ (key agreement)}$$

Vulnerabilities of NS-PK Protocol

6

This protocol provides no guarantee that the public keys obtained by the client principals are current (Denning and Sacco)

This problem can be overcome in various ways for example, by including timestamps in the key deliveries.

We can assume that the client's public keys that are obtained from Trent are current and good

In 1995, almost 20 years after the NS-PK protocol was published, Lowe showed that the protocol has some vulnerabilities

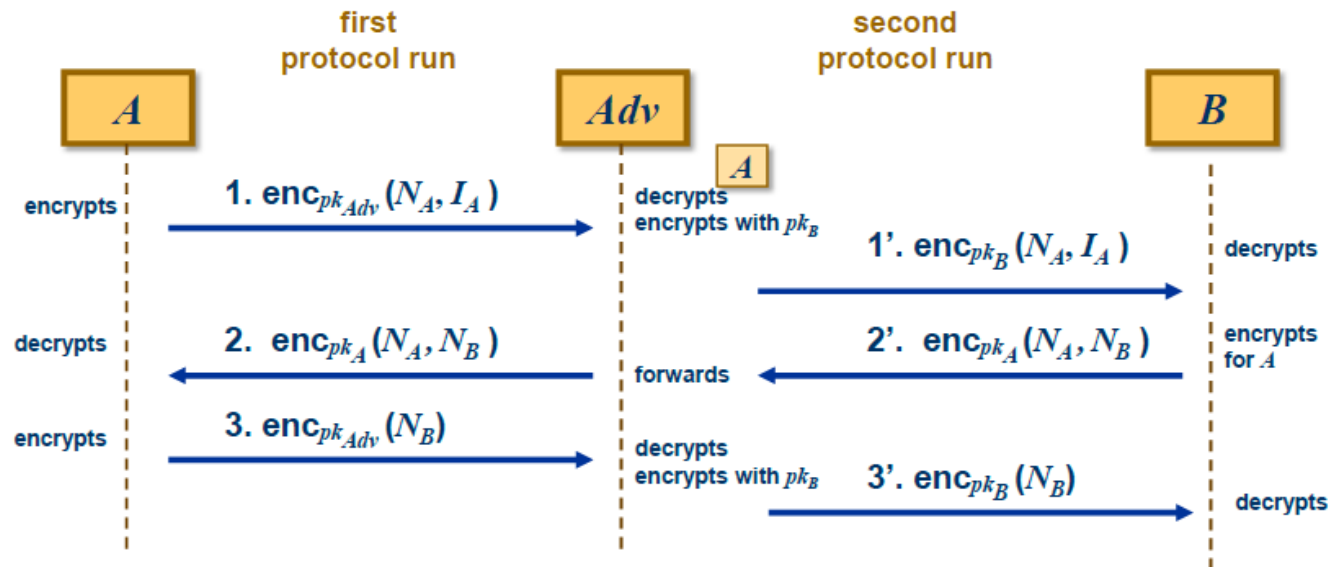
B cannot be sure that the final message came from A

The attack on the protocol allows an adversary *Adv* to impersonate a party *A* and to set up a false session with *B*

The attack involves two simultaneous runs of the protocol

Lowe's Attack on NS-PK Protocol

7



In run I : *A* establishes a valid session with *Adv*

In run II: *Adv* impersonates *A* and establishes a fake session with *B*

→ authentication failed !!!

Analysis of Lowe's Attack (1)

- **Step I.1**

- A starts to establish a normal session with Adv , sending it a nonce N_A

- **Step II.1**

- Adv impersonates A to try to establish a false session with B , sending it a nonce N_A obtained in the previous message

- **Step II.2**

- B responds by selecting a new nonce N_B , and trying to return it, along with N_A , to A
 - The adversary intercepts this message but cannot decrypt it because it is encrypted with A 's key. The adversary therefore tries to use A as an oracle, by forwarding the message to it

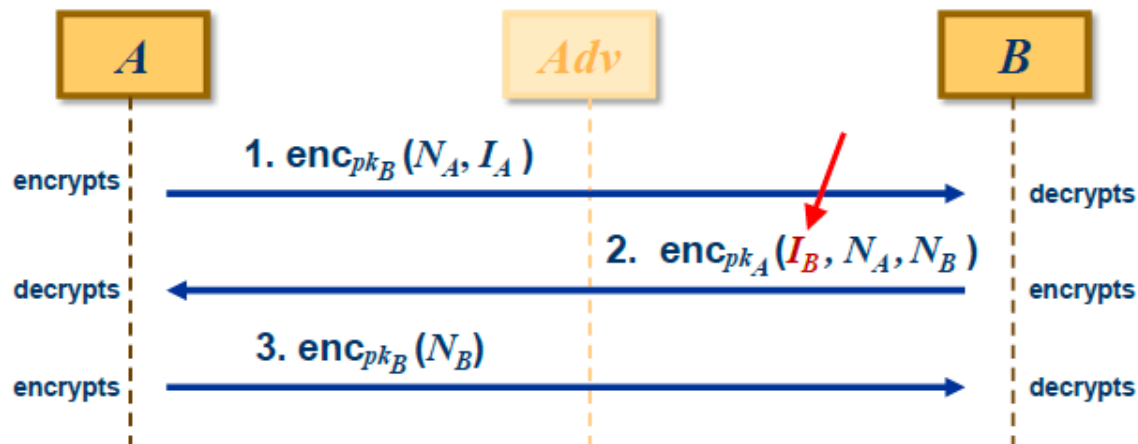
Analysis of Lowe's Attack (2)

9

- **Step I.2**
 - The adversary Adv simply forwards the received message to A
 - This message is of the form expected by A in run I of the protocol
- **Step I.3**
 - A decrypts the message to obtain N_B
 - And returns it to Adv
- **Step II.3**
 - Adv decrypts the received message and obtains N_B
 - Returns N_B to B , and thus is able to complete run II of the protocol
 - Hence, B believes that A has correctly established a session with it

The adversary

Fixing the NS-PK Protocol



- **Proposal of Lowe to prevent the attack**
 - Include the responder's identity I_B in message 2
 - The protocol is known as Needham-Schroeder-Lowe (NSL) protocol